

DUE DILIGENCE OSINT

White Paper Tecnico-Operativo Definitivo

In conformità al GDPR, al Codice Privacy italiano e alla normativa di settore

Versione 1.0 | Marzo 2026

ARA Legal

Executive Summary

La due diligence OSINT (Open Source Intelligence) costituisce uno strumento preliminare essenziale per la valutazione del rischio legale, reputazionale e operativo di aziende e persone fisiche, in contesti commerciali, di compliance e di governance. Attraverso l'analisi strutturata di fonti aperte e pubblicamente disponibili, l'OSINT consente di individuare indicatori di rischio (red flag) prima dell'instaurazione di rapporti contrattuali, partnership o incarichi professionali, riducendo l'esposizione a contenziosi, frodi e danni reputazionali.

Nel 2026, l'OSINT ha superato i confini delle agenzie governative per diventare un pilastro della governance aziendale, guidata dalla convergenza tra l'esplosione dei dati pubblici, l'adozione massiva dell'intelligenza artificiale agentica e un quadro regolatorio europeo sempre più pervasivo. La necessità di condurre analisi preventive non risponde più solo a criteri di prudenza commerciale, ma è diventata un requisito di compliance indispensabile.

Il presente documento integra e aggiorna i seguenti elementi metodologici:

- Analisi sistematica del quadro normativo italiano ed europeo aggiornato al 2026
- Metodologia operativa articolata in 6 fasi, conforme GDPR
- Tassonomia completa delle fonti lecite e critiche
- Ecosistema degli strumenti OSINT per il 2026
- Protocolli di OPSEC (Operational Security) per gli analisti
- Framework per il Legitimate Interest Assessment (LIA) secondo EDPB 1/2024
- Check-list operative verificabili per aziende e persone fisiche
- Protocolli di documentazione, tracciabilità e conservazione dei dati
- Analisi delle minacce emergenti: deepfake-as-a-service, frodi sintetiche, AI agentica
- Riferimenti bibliografici e normativi completi

⚠ Il presente report NON sostituisce attività investigative riservate o verifiche ufficiali. Costituisce uno strumento di analisi preventiva del rischio, utilizzabile in modo lecito, proporzionato e difendibile in ottica di governance, compliance e responsabilità organizzativa.

1. Introduzione

1.1 Definizione e Contesto dell'OSINT

L'Open Source Intelligence (OSINT) è un'attività di intelligence basata esclusivamente su fonti pubbliche e legalmente accessibili. Storicamente introdotta durante la Seconda Guerra Mondiale, ha ricevuto riconoscimento istituzionale strutturato negli anni '90: il National Security Act (1992) promosso dal senatore David Boren incluse un ufficio dedicato alle fonti aperte, mentre la Commissione Aspin-Brown (1996) sottolineò come il ricorso a tali fonti fosse gravemente insufficiente. Il rapporto della 9/11 Commission (2004) raccomandò la creazione di un'agenzia dedicata, concretizzatasi nel 2005 con il DNI Open Source Center.

Nel 2026, l'OSINT è applicabile a molteplici ambiti: intelligence commerciale, investigazione giudiziaria, compliance, gestione del rischio, cybersecurity e Social Network Analysis. Nel contesto italiano, è disciplinata indirettamente da norme sulla protezione dei dati personali e sulle investigazioni private, piuttosto che da una legislazione specifica.

1.2 La Trasformazione dell'OSINT nel 2026

Le imprese utilizzano oggi queste metodologie per proteggersi in modo proattivo da minacce esterne, monitorando piattaforme social, database commerciali e segnali provenienti dal web profondo. La professionalizzazione del settore ha portato allo sviluppo di strategie e protocolli che consentono di integrare i dati OSINT con le informazioni interne, facilitando decisioni rapide e informate su partner commerciali, fornitori e candidati executive.

Il 2026 è caratterizzato da tre macro-trend tecnologici che ridefiniscono il panorama operativo:

- IA Agentica: Bot autonomi per raccolta e analisi dati, passaggio da investigazione reattiva a monitoraggio proattivo
- Generative UI: Interfacce dinamiche che creano visualizzazioni ad hoc per il problema investigativo corrente
- Deepfake-as-a-Service (DaaS): Industrializzazione della frode sintetica, con impatto diretto sulla reputational due diligence

1.3 Ambito e Finalità del Report

Questo report fornisce una guida tecnico-operativa per l'esecuzione di due diligence OSINT su aziende e persone fisiche, con attenzione alla conformità al GDPR, al Codice Privacy italiano, al D.Lgs. 231/2001, al TULPS e alla normativa antiriciclaggio. Il modello operativo adottato è quello del 'centauro': l'IA gestisce il carico di lavoro pesante (raccolta, sintesi), mentre l'esperto umano fornisce l'ipotesi creativa e i parametri etici.

2. Quadro Normativo Italiano ed Europeo

2.1 Tavola di Sintesi Normativa

La seguente tabella riassume le principali norme applicabili all'OSINT in Italia, aggiornata ai provvedimenti del 2026:

Norma	Contenuto Chiave per OSINT	Implicazioni Operative
Art. 5 GDPR	Principi di minimizzazione e accountability	Raccolta limitata allo scopo; documentazione obbligatoria ex-ante
Art. 6.1.f GDPR	Legittimo Interesse	Base giuridica principale; richiede LIA documentato e approvato
Art. 9 GDPR	Dati Sensibili (categorie particolari)	Divieto generale; eccezione solo per dati 'manifestamente resi pubblici'
Art. 22 GDPR	Profilazione automatizzata	Vietato profiling automatico con effetti significativi sull'individuo
Art. 35 GDPR	DPIA	Obbligatoria per trattamenti ad alto rischio (grandi volumi, dati sensibili)
D.Lgs. 196/2003 (Codice Privacy)	Art. 167 - Trattamento illecito	Responsabilità penale per trattamento dati in violazione del Codice
D.Lgs. 231/2001	Responsabilità amministrativa enti	OdV richiede intelligence OSINT preventiva su rischi reputazionali/penali
Art. 134-140 TULPS	Licenza investigatore privato	Distingue consultazione fonti pubbliche (lecita) da investigazione privata (licenza)
Artt. 4-8 L. 300/1970 (Statuto Lav.)	Divieto indagini su opinioni	Vietato raccogliere dati su opinioni politiche, religiose, sindacali dei lavoratori
Art. 615-ter CP	Accesso abusivo a sistemi informatici	Reclusione fino a 8 anni per accesso non autorizzato a database riservati
Art. 594-616 CP	Diffamazione e violazione privacy	Responsabilità penale per diffusione illecita di informazioni personali
EDPB Guidelines 1/2024	Legitimate Interest Assessment	Framework vincolante per la strutturazione del LIA in tre test
Digital Omnibus Regulation 2026	Joint Opinion 2/2026 EDPB/EDPS	Semplificazione notifiche breach; modelli comuni DPIA; tutela definizione dato personale

2.2 Il Regolamento (UE) 2016/679 (GDPR)

Il GDPR rappresenta il fondamento primario dell'OSINT in Italia. Ogni trattamento di dati personali deve rispettare i principi di liceità, correttezza e trasparenza (Art. 5).

2.2.1 Principi Fondamentali (Art. 5 GDPR)

- Liceità, correttezza e trasparenza (lett. a): Il trattamento deve basarsi su una base giuridica valida (Art. 6) ed essere effettuato in modo corretto e trasparente verso l'interessato
- Limitazione della finalità (lett. b): I dati devono essere raccolti per finalità determinate, esplicite e legittime
- Minimizzazione dei dati (lett. c): Principio cardine per l'OSINT – dati 'adeguati, pertinenti e limitati a quanto necessario'
- Esattezza (lett. d): I dati devono essere esatti e, ove necessario, tenuti aggiornati
- Limitazione della conservazione (lett. e): I dati non devono essere conservati più a lungo del necessario
- Integrità e riservatezza (lett. f): Sicurezza adeguata contro trattamenti non autorizzati

Il principio di accountability (Art. 5.2) richiede ai titolari di documentare ex-ante: (i) la base giuridica, (ii) la necessità e proporzionalità, (iii) le misure di sicurezza, (iv) il processo di cancellazione dati al termine dell'indagine.

2.2.2 Basi Giuridiche (Art. 6 GDPR)

Per la due diligence OSINT commerciale, la base più frequente è il legittimo interesse (Art. 6.1.f). Richiede il superamento di un LIA formale (v. Appendice B). Altre basi applicabili:

- Obbligo Legale (Art. 6.1.c): Per compliance AML/KYC obbligatori
- Interesse Pubblico (Art. 6.1.e): Per pubbliche amministrazioni

2.2.3 Categorie Particolari di Dati (Art. 9 GDPR)

Vietato raccogliere dati rivelanti origine razziale/etnica, opinioni politiche, convinzioni religiose, appartenenza sindacale, dati genetici, biometrici, sanitari, vita sessuale. Eccezione per dati 'manifestamente resi pubblici dall'interessato', ma da interpretare restrittivamente: la pubblicazione deve essere stata una scelta consapevole dell'individuo, non il risultato di azioni di terzi o data breach.

2.3 Normative Nazionali

2.3.1 D.Lgs. 196/2003 (Codice Privacy) – Modificato dal D.Lgs. 101/2018

- Art. 167: Punisce penalmente il trattamento illecito di dati personali
- Art. 3 (Principio di necessità): Trattamento lecito solo se necessario rispetto alle finalità dichiarate
- Artt. 13-14: Obbligo di informazione agli interessati (con eccezioni in contesti investigativi)

2.3.2 D.Lgs. 231/2001 – Responsabilità Amministrativa degli Enti

Gli Organismi di Vigilanza (OdV) richiedono intelligence OSINT preliminare su rischi reputazionali e penali. L'OSINT praticata dall'azienda deve essere conforme ai principi del Modello Organizzativo Gestionale (liceità, trasparenza, minimizzazione).

2.3.3 TULPS (Artt. 134 e 140) e D.M. 269/2010

L'Art. 134 vieta investigazioni per conto di privati senza licenza del Prefetto. L'OSINT condotta da aziende, studi legali o analisti interni che utilizzi esclusivamente fonti pubbliche non costituisce 'investigazione privata' e non richiede licenza prefettizia. Art. 140 TULPS: reclusione fino a 2 anni per esercizio abusivo.

2.3.4 Statuto dei Lavoratori (L. 300/1970, Artt. 4 e 8)

Art. 8 vieta indagini su opinioni politiche, religiose o sindacali dei lavoratori. È lecito raccogliere informazioni pubbliche sulla carriera professionale (LinkedIn, stampa), ma vietato raccogliere o utilizzare informazioni su opinioni, salute, vita privata.

⚠ CASO AMAZON – Febbraio 2026 (Prov. n. 107 del 24/02/2026, Doc-Web 10224096): Il Garante Privacy ha vietato il trattamento dati per oltre 1.800 lavoratori, accertando l'uso dell'algoritmo 'Bradford Factor' per penalizzare le assenze e l'annotazione illegale di dati sanitari (pacemaker, diagnosi psichiatriche) e personali (separazioni, hobby) nei 'campi liberi' della piattaforma gestionale. Ribadisce che la raccolta sistematica di informazioni non pertinenti alla valutazione professionale viola i principi di liceità e minimizzazione.

2.4 Novità Normative 2026

2.4.1 Digital Omnibus Regulation e Joint Opinion 2/2026 EDPB/EDPS

L'inizio del 2026 è segnato dall'adozione del Joint Opinion 2/2026 da parte dell'EDPB e dell'EDPS riguardo alla proposta di Digital Omnibus Regulation. Le autorità hanno espresso riserve sul tentativo di restringere la definizione di 'dato personale'. Sono stati accolti favorevolmente: semplificazione degli obblighi di notifica dei data breach e introduzione di modelli comuni e liste per le DPIA.

2.4.2 Corporate Transparency Act (USA) e FinCEN – Residential Real Estate Rule (1° Marzo 2026)

Entra in vigore la Residential Real Estate Rule: i professionisti del settore immobiliare devono segnalare i trasferimenti di proprietà a entità legali o trust effettuati senza finanziamento bancario. Il FinCEN ha introdotto semplificazioni (exceptive relief) per le istituzioni finanziarie, permettendo di non verificare i beneficiari effettivi per ogni apertura di conto se il cliente è già noto.

3. Principi di Base dell'OSINT Conforme

3.1 I Tre Principi Cardinali

3.1.1 Liceità

La raccolta di dati deve basarsi su una base giuridica valida (Art. 6 GDPR). In contesti di due diligence commerciale, la base più comune è il legittimo interesse, condizionato al superamento di un LIA formale (v. Appendice B). Il LIA richiede di documentare:

- Purpose Test: Quale interesse concreto ed effettivo il titolare persegue (es. evitare frodi, verificare affidabilità)
- Necessity Test: Se il trattamento è effettivamente necessario e se esistono alternative meno invasive
- Balancing Test: Se l'interesse del titolare prevale sui diritti e libertà dell'interessato

3.1.2 Proporzionalità

La raccolta e l'analisi devono essere proporzionate rispetto all'obiettivo perseguito. Non è ammessa raccolta massiccia, indiscriminata o 'fishing expedition'. In pratica:

- Raccogliere solo dati rilevanti alla finalità (minimizzazione Art. 5.1.c GDPR)
- Escludere dati sensibili salvo necessità specifica documentata
- Definire ex-ante il periodo di raccolta e lo scope dell'indagine
- Cancellare dati non più necessari alla scadenza della finalità

3.1.3 Finalità

I dati raccolti per una finalità non possono essere utilizzati per finalità diverse (Art. 5.1.b GDPR). Un'indagine OSINT condotta per due diligence commerciale non può essere riutilizzata per scopi disciplinari verso dipendenti o per marketing senza una nuova base giuridica.

3.2 Trasparenza, Accountability e Privacy by Design

- Trasparenza: Gli interessati devono essere informati, ove possibile e non controindicato, del trattamento dei loro dati
- Accountability: Documentare ex-ante e durante: (i) la base giuridica (LIA), (ii) le fonti consultate, (iii) le misure di sicurezza, (iv) il processo di cancellazione dati
- Privacy by Design: Le misure di protezione devono essere integrate nel design dell'indagine, non aggiunte a posteriori

3.3 Operational Security (OPSEC) dell'Analista

Nel 2026, condurre un'indagine da un indirizzo IP domestico o da un account personale è considerato un errore metodologico grave. L'analista moderno deve adottare difese stratificate:

- Hardware dedicato: Dispositivi separati per le attività investigative
- Catene complesse di VPN: Per proteggere l'impronta digitale
- Identità operative (Personas): Profili che non possano essere collegati alla vera identità dell'analista
- Competenze tecniche: Python per automazione ricerche, conoscenza di DNS, routing IP, rendering browser

⚠ PRINCIPIO DI OPSEC: L'investigatore deve assumere che, se sta indagando su un attore pericoloso, l'attore lo stia a sua volta cercando.

4. Fonti Lecite vs Fonti Critiche

4.1 Fonti Lecite – Registro Completo

Fonte	Accesso	Tipo di Dato	Applicabilità
Registro Imprese	Libero/Telematico	Dati societari, soci, bilanci, modifiche	Due diligence aziende
Gazzetta Ufficiale	Libero online	Scioglimenti, fallimenti, concordati, avvisi	Rischi insolvenza
Portale Giustizia (giustizia.it)	Database pubblico	Sentenze depositate, contenziosi	Precedenti giudiziari
Banca Dati Cassazione	Database pubblico	Giurisprudenza Corte Cassazione	Precedenti consolidati
Ordini Professionali	Pubblico online (albi)	Iscrizione, sospensioni, radiazioni	Verifica abilitazioni
Agenzia Entrate	Accesso parziale	Informazioni fiscali pubbliche	Verifica registrazione legale
INPS/INAIL	Accesso parziale	Contributi, infortuni (dati parziali)	Compliance sicurezza lavoro
Liste PEP/OFAC/UE	Pubblico	Persone Politicamente Esposte, sanzioni	AML/KYC obbligatorio
Cerved/CRIF/Cribis	Abbonamento commerciale	Rating solvibilità, comportamento creditizio	Analisi finanziaria
LinkedIn (profilo pubblico)	Web aperto	Carriera, formazione, raccomandazioni	Due diligence persone
Google News / Archivi stampa	Web aperto	Articoli, inchieste, controversie etiche	Reputazione mediatica
OpenCorporates	Libero online	Database societario globale	Aziende estere
BORIS (Reg. UBO UE)	Legittimo interesse	Beneficiari effettivi cross-border	Trasparenza proprietà
Companies House (UK)	Accesso pubblico	Dati societari UK verificati	Partner esteri UK

4.2 Fonti Critiche e Non Lecite

4.2.1 Accesso Non Autorizzato a Sistemi Informatici

L'accesso senza credenziali a database amministrativi (es. ANPR) costituisce il reato di accesso abusivo a sistema informatico (Art. 615-ter CP):

- Reclusione fino a 3 anni (caso base)
- Reclusione da 1 a 5 anni se il colpevole è un pubblico ufficiale che abusa dei propri poteri
- Reclusione da 3 a 8 anni se i sistemi sono di interesse militare, ordine pubblico, sanità, protezione civile o ambiente

4.2.2 Deep Web / Dark Web

- Accesso a mercati illegali (compravendita di dati, credenziali rubate, documenti falsificati): ILLECITO
- Utilizzo di leak dataset da data breach: problematico legalmente; rischio significativo di responsabilità civile e penale

4.2.3 Scraping Aggressivo

- Utilizzo di bot per estrarre massivamente dati senza autorizzazione: viola diritti d'autore e ToS
- Circumvenzione di misure anti-scraping: NON LECITO

4.2.4 Intercettazioni e Comunicazioni Private

- Acquisizione di email, messaggi privati, conversazioni senza consenso: REATO penale (Art. 616 CP)
- Metadati da comunicazioni telefoniche: vietati salvo provvedimento giudiziale

4.2.5 Raccolta Sistemática di Dati Sensibili Senza Necessità

- Raccolta indiscriminata di informazioni su salute, origine etnica, opinioni politiche, dati genetici: vietata (Art. 9 GDPR)
- Eccezione: Due diligence AML/KYC rafforzata su PEP, ove le esposizioni politiche pubbliche siano necessarie per identificare conflitti di interesse

5. Metodologia Operativa – Le 6 Fasi

5.1 Fase 1 – Pianificazione e Analisi Preliminare

Questa fase definisce il perimetro dell'indagine. Stabilire chiaramente:

- Chi è il soggetto dell'indagine: azienda, persona fisica, gruppo di soggetti correlati?
- Qual è la finalità: due diligence commerciale, compliance AML, verifica di onorabilità, analisi competitiva?
- Chi è il 'titolare del trattamento': azienda, studio legale, investigatore privato autorizzato?
- Qual è il periodo temporale: analisi quanto indietro? Monitoraggio continuo?
- Quali dati servono realmente: minimizzazione – per compliance AML non servono foto personali, ma dati su esposizioni politiche

5.1.1 Valutazione d'Impatto Privacy (DPIA)

Se l'indagine riguarda grandi volumi di dati personali, dati sensibili o monitoraggio continuo, è consigliata una DPIA formale (Art. 35 GDPR). Documentare: natura, oggetto, contesto e finalità; necessità e proporzionalità; rischi per diritti e libertà; misure di mitigazione; coinvolgimento del DPO.

5.1.2 Identificazione della Base Giuridica

- Legittimo Interesse (Art. 6.1.f GDPR): Per valutare rischi commerciali, compliance, frodi. Richiede LIA formale
- Obbligo Legale (Art. 6.1.c GDPR): Per compliance AML/KYC
- Interesse Pubblico (Art. 6.1.e GDPR): Per pubbliche amministrazioni

5.2 Fase 2 – Identificazione e Consultazione delle Fonti

5.2.1 Aziende – Template di Raccolta Fonti

- Dati anagrafici e societari: Registro Imprese (natura giuridica, assetti societari, soci)
- Governance e controlli: siti aziendali ufficiali, dichiarazioni policy, certificazioni
- Precedenti legali: giustizia.it (sentenze depositate, contenziosi civili)
- Reputazione mediatica: Google News, archivi stampa storici
- Compliance e sanzioni: Liste PEP, OFAC, database rating (Cerved, Cribis)
- Beneficiari effettivi: BORIS per cross-border UE, Companies House per UK

5.2.2 Persone Fisiche – Template di Raccolta Fonti

- Profilo professionale: LinkedIn (profilo pubblico), Registri Ordini Professionali
- Esposizione mediatica: Google News, menzioni in forum rilevanti
- Precedenti giudiziari: Sentenze pubbliche disponibili su giustizia.it
- Conflitti di interesse: Dichiarazioni di carica pubblica, esposizioni politiche dichiarate

5.3 Fase 3 – Protocollo di Raccolta e Documentazione

5.3.1 Strumenti Autorizzati

- Motori di ricerca avanzati: Google (operatori site:, filetype:, inurl:, intitle:), Bing
- OSINT tools conformi: Maltego (community version), Shodan (dati pubblici su infrastrutture)
- Evitare: tool che integrano leaked database, dark web data, accessi non autorizzati

5.3.2 Audit Trail – Protocollo Obbligatorio

Per ogni fonte consultata, creare una scheda che registri:

- Nome della fonte e URL completo
- Data e ora di accesso (con timestamp verificabile)
- Dati estratti e sintesi

- Screenshot o download per tracciabilità
- Note di rilevanza e valutazione preliminare

5.3.3 Verifica Incrociata

Confrontare informazioni da fonti diverse per verificare accuratezza: dati Registro Imprese (fonte primaria) vs LinkedIn (fonte secondaria); CV dichiarato vs storia lavorativa in stampa. Identificare incoerenze e falsità.

5.4 Fase 4 – Analisi e Valutazione del Rischio

5.4.1 Applicazione del Principio di Minimizzazione

Dopo la raccolta, escludere dati non pertinenti alla finalità. Esempio: per compliance AML, le esposizioni politiche sono pertinenti; il colore dell'auto non lo è.

5.4.2 Social Network Analysis (SNA) – Mapping Relazionale

Per analisi complesse, utilizzare tool di network analysis (es. Gephi, Maltego) per visualizzare: chi è amministratore di quali aziende; chi è collegato tramite cariche pubbliche; chi è legato da patti parasociali o diritti di veto.

Nel 2026, la metodologia SURVEY2MLN utilizza LLM per estrarre entità e inferire relazioni da dati non strutturati, creando grafi multistrato con layer di collaborazione, skill condivise, affiliazione organizzativa e influenza sociale.

5.4.3 Red Flag per Aziende

- Modifiche societarie sospette (es. cambio rapido di amministratori poco prima di contenziosi)
- Bilanci con risultati anomali (calo drastico fatturato, perdite reiterate)
- Procedure concorsuali (fallimento, concordato) anche storiche
- Procedimenti penali per reati gravi (corruzione, riciclaggio, frodi)
- Associazioni con soggetti sanzionati o PEP senza disclosure pubblica
- Reputazione mediatica negativa (inchieste, controversie etiche, scandali ambientali)

5.4.4 Red Flag per Persone Fisiche

- Contenziosi giudiziari (civili, penali) documentati
- Carriera discontinua o incoerente con dichiarazioni (CV falso o modificato)
- Esposizioni politiche non dichiarate (PEP) in contesti dove richiesto
- Dichiarazioni pubbliche controverse (opinioni radicali, hate speech)
- Associazioni con soggetti/entità a rischio
- Indicatori di conflitto di interesse non rivelato

5.4.5 Matrice di Valutazione del Rischio

Livello Rischio	Descrizione	Indicatori Tipici	Azione
Alto	Evidenza significativa di problematiche legali, etiche o reputazionali	Procedimenti penali attuali, fallimenti recenti, sanzioni AML, sospensioni professionali	Stop / Escalation
Medio	Indicazioni che meritano approfondimento ulteriore	Contenziosi civili risolti, modifiche societarie frequenti, reputazione mediatica ambigua	Approfondire
Basso	Nessun indicatore significativo di problematica	Assenza di dati negativi, coerenza informazioni, reputazione stabile, conformità normativa verificata	Procedere
Insufficiente	Informazioni disponibili non adeguate a valutazione conclusiva	Scarsa traccia digitale, informazioni obsolete, impossibilità di verifica incrociata	Richiedere dati

5.5 Fase 5 – Redazione del Report Conforme

5.5.1 Principi di Redazione

- Linguaggio neutro e non accusatorio: evitare termini che suggeriscono conclusioni penali (es. NON 'la persona è corrotta' → SÌ 'emergono indicatori di potenziale conflitto di interesse non dichiarato, fonte X')
- Distinzione fra fatti, fonti e valutazioni: separare cosa è stato documentato, da dove proviene, e quale è l'interpretazione dell'analista
- Tracciabilità della fonte: ogni affermazione deve citare la fonte (URL, data accesso, database)
- Disclaimer legale: chiarire i limiti dell'OSINT, l'incompletezza dell'analisi, la natura preliminare del report

5.5.2 Struttura Consigliata del Report

- Intestazione: soggetto, data, finalità, fonti utilizzate, periodo analizzato, classificazione
- Disclaimer e limitazioni metodologiche
- Dati anagrafici e societari
- Analisi finanziaria e patrimoniale
- Precedenti giudiziari e contenziosi
- Reputazione mediatica e social
- Governance e compliance
- Valutazione del rischio complessivo con livello (Alto/Medio/Basso/Insufficiente)
- Raccomandazioni operative

5.6 Fase 6 – Conservazione Dati e Cancellazione

5.6.1 Misure di Sicurezza

- Accesso limitato: Solo personale autorizzato può consultare il report
- Crittografia: Dati sensibili archiviati in formato crittografato (AES-256 o equivalente)
- Audit trail: Log di chi ha acceduto il report, quando, da dove
- Backup: Copia in luogo sicuro, separato dalla copia operativa

5.6.2 Periodo di Conservazione

- 6-12 mesi post-indagine per due diligence commerciale singola
- 12-24 mesi per monitoraggio continuativo di fornitori
- Cancellare completamente al termine, incluso backup
- Certificato di distruzione/cancellazione per documenti sensibili

6. Check-list Operative

6.1 Check-list OSINT per Aziende

Identificazione e Dati Societari

- ☐ Ragione sociale, CF/P.IVA, natura giuridica (SpA, SRL, ecc.), stato (attiva, sospesa, cancellata)
- ☐ Sede legale, sedi operative, filiali
- ☐ Data di iscrizione al Registro Imprese e storico modifiche

Assetti Societari e Governance

- ☐ Amministratori attuali: nome, data nascita, CV
- ☐ Soci principali e titolari effettivi (beneficial owners) – verifica BORIS
- ☐ Modifiche storiche: cambi amministratori, aumenti capitale, fusioni
- ☐ Organi di controllo (sindaci, revisori)
- ☐ Organismo di Vigilanza 231/2001 (ove applicabile)
- ☐ Codice etico / policy anticorruzione (se pubblico)
- ☐ Certificazioni di compliance (ISO, qualità, ambiente)

Analisi Finanziaria e Solvibilità

- ☐ Bilancio ultimi 3-5 anni: fatturato, utili, capitale sociale
- ☐ Trend fatturato e redditività
- ☐ Rating di solvibilità (Cerved, Cribis, CRIF)
- ☐ Fallimenti storici e date
- ☐ Concordati preventivi, amministrazione controllata o straordinaria

Precedenti Giudiziari e Sanzioni

- ☐ Procedimenti penali conclusi (sentenze depositate)
- ☐ Imputazioni per reati gravi (corruzione, riciclaggio, frodi)
- ☐ Contenziosi civili significativi
- ☐ Sanzioni amministrative (antitrust, ambiente, lavoro)
- ☐ Verifica lista PEP (se azienda controllata da PEP)
- ☐ Screening liste OFAC, UE, antiterrorismo
- ☐ Segnalazioni UIF antiriciclaggio

Reputazione Mediatica

- ☐ Articoli di stampa (positivi, negativi, neutri) ultimi 5 anni
- ☐ Inchieste giornalistiche su scandali, frodi, corruzione
- ☐ Controversie etiche o ambientali
- ☐ Valutazione sentiment: numero menzioni positive vs negative

Minacce Emergenti – Controlli 2026

- ☐ Verifica autenticità media (deepfake check) per comunicazioni ufficiali ricevute
- ☐ Screening su database di identità sintetiche note
- ☐ Analisi blockchain (se attività in criptovalute)

6.2 Check-list OSINT per Persone Fisiche

Identificazione e Profilo Professionale

- ☐ Nome, cognome, data di nascita, indirizzo pubblico (se disponibile)
- ☐ Posizione attuale e azienda di appartenenza
- ☐ Esperienze lavorative precedenti (verificabili da LinkedIn o stampa)
- ☐ Educazione e titoli dichiarati (verifica con fonti primarie)
- ☐ Profili pubblici su social media (LinkedIn, Twitter, Facebook pubblico)

Abilitazioni Professionali

- ☐ Iscrizione albi professionali (avvocati, medici, commercialisti, ecc.)
- ☐ Stato iscrizione (attiva, sospesa, radiata)
- ☐ Sospensioni o sanzioni professionali storiche

Esposizione Mediatica e Reputazione

- ☐ Menzioni su articoli di stampa (negli ultimi 5-10 anni)
- ☐ Apparizioni pubbliche, interviste, dichiarazioni rilevanti
- ☐ Tono complessivo dei contenuti (positivo, neutro, negativo)
- ☐ Affiliazioni pubbliche dichiarate (partiti, associazioni)
- ☐ Social media: dichiarazioni pubbliche, post rilevanti, sentiment

Precedenti Legali e Conflitti

- ☐ Procedimenti penali conclusi (sentenze pubbliche disponibili)
- ☐ Contenziosi civili (se tracciabili da fonti pubbliche)
- ☐ Sanzioni professionali (sospensione, radiazione ordine)
- ☐ Insolvenze, pignoramenti (se tracciabili da fonti pubbliche)
- ☐ Cariche multiple non dichiarate, relazioni familiari rilevanti
- ☐ Verifica liste PEP, OFAC (ove rilevante)

Indicatori di Rischio Specifici

- ☐ Coerenza fra CV dichiarato e storia professionale in stampa
- ☐ Associazioni con personalità controverse
- ☐ Inconsistenze fra dichiarazioni e realtà verificabile
- ☐ Segnali di identità sintetica o account gestito da terzi (2026)

7. Errori Comuni e Rischi Legali

7.1 Profiling Illecito

Errore: Raccogliere massivamente dati su caratteristiche protette per creare profili discriminatori.

Rischio Legale: Violazione GDPR Art. 9, Art. 22 (profiling automatico); sanzioni fino a 20 milioni di euro o 4% del fatturato globale annuo.

Mitigazione: Limitare raccolta a dati strettamente necessari; escludere categorie particolari salvo esplicita necessità documentata in LIA.

7.2 Conservazione Indebita

Errore: Mantenere dati oltre il termine necessario (es. conservare dati su persona indagata 3 anni dopo che non è più controparte).

Rischio Legale: Violazione principio di 'storage limitation' (Art. 5.1.e GDPR); sanzionabile fino a 20 milioni di euro.

Mitigazione: Definire ex-ante periodo di conservazione; implementare processo di cancellazione certificata.

7.3 Riutilizzo Improprio

Errore: Utilizzare dati raccolti per due diligence commerciale a finalità diverse senza nuova base giuridica.

Rischio Legale: Violazione 'purpose limitation' (Art. 5.1.b GDPR); non conformità Art. 6.

Mitigazione: Documentare chiaramente finalità dichiarate; ottenere LIA separata se finalità evolve.

7.4 Diffamazione e Abuso di Dati

Errore: Diffondere informazioni OSINT in modo pubblico senza verifiche adeguate.

Rischio Legale: Diffamazione (Art. 594 CP, fino a 3 anni); responsabilità civile per danno reputazionale.

Mitigazione: Mantenere report riservato; accesso solo a personale autorizzato; linguaggio neutro; disclaimer.

7.5 Accesso Abusivo a Database

Errore: Utilizzo di credenziali non autorizzate o account borrowing per accedere a banche dati riservate.

Rischio Legale: Reato Art. 615-ter CP (accesso abusivo), fino a 8 anni in casi aggravati.

Mitigazione: Accesso solo con credenziali proprie; no account sharing; authorization trail per ogni query.

7.6 Scraping Aggressivo e Violazione Copyright

Errore: Estrazione massiccia tramite bot, violando robots.txt o ToS della piattaforma.

Rischio Legale: Violazione copyright, ToS; responsabilità civile; blocco IP/account.

Mitigazione: Ricerca manuale o utilizzo di API pubbliche; rispetto robots.txt; consultazione ToS.

7.7 Mancanza di Tracciabilità (Accountability)

Errore: Assenza di documentazione su chi ha raccolto dati, quando, da quali fonti, per quale finalità.

Rischio Legale: Impossibilità di provare conformità GDPR in caso di audit Garante; presunzione di trattamento illecito; sanzioni fino a 20 milioni di euro.

Mitigazione: Implementare audit trail (log di accesso), documentare LIA, policy OSINT, formazione personale.

7.8 Minacce Emergenti 2026 – Identità Sintetiche e Deepfake

Errore: Non verificare l'autenticità di documenti, video, audio e identità dei soggetti indagati nell'era dei Deepfake-as-a-Service.

Rischio: Decisioni aziendali basate su profili sintetici fraudolenti; CEO fraud; perdite finanziarie significative.

Mitigazione: Utilizzare strumenti di rilevamento deepfake (UNCOVAI, analisi biometrica); applicare verifica multi-canale; richiedere azioni imprevedibili durante le interazioni live per smascherare IA.

8. Casi Pratici

8.1 Caso Pratico 1 – Due Diligence Commerciale su Azienda

Scenario

L'azienda TechMart S.r.l. (fabbrica di componenti elettronici) intende entrare in partnership con GlobalSupply Ltd., azienda estera di intermediazione commerciale. Prima della firma del contratto, TechMart incarica uno studio legale di condurre due diligence OSINT per verificare affidabilità e compatibilità AML/KYC.

Pianificazione

- Finalità: Valutazione rischio commerciale, compliance AML/KYC
- Titolare: Studio legale su incarico TechMart
- Base giuridica: Legittimo interesse – LIA formulato e archiviato
- Periodo: Analisi ultimi 5 anni
- Minimizzazione: Solo dati su proprietà, governance, procedimenti legali, reputazione

Risultati Raccolta Dati

- Registro Imprese UK (Companies House): Amministratori: John Smith, Jane Doe; Soci: Private Investment Fund XYZ (50%), John Smith (50%); Bilancio 2023: 10M fatturato, 1.2M utile; Cambio amministratore 2022 (Brown → Smith, motivo non specificato)
- Google News: Financial Times (2023): 'GlobalSupply expands European operations' (positivo); Telegraph (2021): 'GlobalSupply faces supply chain dispute' (rischio medio, risolto)
- LinkedIn: John Smith (CEO): 20 anni esperienza supply chain, precedenti affidabili; Jane Doe (CFO): background finanziario solido
- Screening AML/KYC: Nessun PEP; Nessuna corrispondenza OFAC/liste antiterrorismo UE

Valutazione Complessiva: RISCHIO BASSO

⚠ Il cambio di amministratore del 2022 senza spiegazione pubblica merita un chiarimento scritto al partner, ma non costituisce un red flag critico in assenza di altri indicatori negativi.

8.2 Caso Pratico 2 – Due Diligence su Candidato Executive

Scenario

Un'azienda del settore finanziario deve nominare un nuovo CFO. Il candidato Marco Rossi ha un profilo apparentemente solido con esperienza in banche di rilevanza sistemica. L'Ufficio Compliance conduce due diligence OSINT per verifica onorabilità e conformità normativa.

Risultati Raccolta Dati

- Albo Dottori Commercialisti: Iscrizione attiva dal 2008; nessuna sanzione; formazione continua regolare
- LinkedIn e Stampa: Carriera coerente; menzioni positive in stampa finanziaria; INCOERENZA: periodo dichiarato in banca X (2015-2018) vs informazioni pubbliche (2016-2019)
- Precedenti Giudiziari: Nessuna sentenza penale; una causa civile con precedente datore di lavoro (2019), risolta con accordo
- PEP e Sanzioni: Non classificato PEP; nessuna corrispondenza OFAC/UE; nessun protesto

Valutazione Complessiva: RISCHIO MEDIO

L'incoerenza temporale nel CV relativa al periodo di lavoro presso una banca (differenza di 1 anno) potrebbe essere dovuta a: periodo di preavviso/non concorrenza, errore nel CV, o tentativo di occultare un periodo.

 *Raccomandazione: Richiedere al candidato un chiarimento scritto sulla discrepanza temporale prima di procedere con l'assunzione. Se soddisfacente, il rischio si abbassa a BASSO.*

8.3 Caso Giurisprudenziale 2026 – Amazon e il Bradford Factor

Riferimento

Provvedimento del Garante Privacy n. 107 del 24 febbraio 2026 (Doc-Web 10224096) – Centro logistico Amazon di Passo Corese.

Violazioni Accertate

- Uso dell'algoritmo Bradford Factor per penalizzare le assenze brevi e frequenti
- Annotazione illegale nei 'campi liberi' della piattaforma gestionale di dati sanitari: pacemaker, interventi chirurgici, diagnosi psichiatriche
- Annotazione di dati personali non pertinenti: coniugi malati terminali, separazioni, hobby
- Telecamere installate troppo vicino a bagni e aree ristoro

Esito e Insegnamenti per OSINT

- Il Garante ha vietato immediatamente il trattamento per oltre 1.800 lavoratori
- INSEGNAMENTO 1: La raccolta sistematica di informazioni non pertinenti alla valutazione professionale viola i principi di liceità e minimizzazione
- INSEGNAMENTO 2: La digitalizzazione non può essere utilizzata per una schedatura indiscriminata della vita dei dipendenti
- INSEGNAMENTO 3: Ogni dato raccolto deve avere una specifica base giuridica e finalità proporzionata

9. Ecosistema degli Strumenti OSINT 2026

9.1 Tavola degli Strumenti Principali

Strumento	Focus Principale	Caratteristiche Distintive
SL Crimewall	Digital Investigation Platform	Gestione ciclo investigativo completo, collaborazione multi-analista, AI behavioral mapping
Maltego	Visual Link Analysis	Mapping di relazioni tra domini, IP e persone tramite trasformazioni grafiche
Lampyre	Forensic OSINT	Aggregazione social media, dark web e registri pubblici con automazione dei report
Intelligence X	Data Leak & Archive Search	Motore specializzato in database leakati e snapshot storiche del web
Recorded Future	Threat Intelligence	Analisi predittiva e monitoraggio in tempo reale dei rischi brand e vulnerabilità
SpiderFoot	Attack Surface Mapping	Automazione raccolta dati da oltre 100 fonti per identificare asset esposti
Shodan / Censys	IoT & Network Discovery	Ricerca dispositivi connessi, monitoraggio vulnerabilità infrastrutture
ShadowDragon	Case Management & SNA	Tracciabilità prove e visualizzazione timeline investigative

9.2 Minacce Emergenti – Deepfake-as-a-Service e Tecniche di Rilevamento

I servizi DaaS hanno democratizzato la capacità di creare video e audio iper-realistici. Secondo il Crypto Crime Report 2026 di TRM, l'attività fraudolenta legata alle criptovalute ha raggiunto i 158 miliardi di dollari nel 2025, con truffatori che utilizzano deepfake per approvare trasferimenti di fondi.

9.2.1 Metodi di Rilevamento

- Analisi Forense dei Metadati: Esame delle 'impronte digitali' dei file per rivelare incoerenze nei dati di creazione e artefatti di compressione
- Rilevamento Inconsistenze Biometriche: Pattern di blinking irregolari, movimenti innaturali della testa, asimmetrie nelle espressioni emotive
- Verifica Audio-Video: Discrepanze tra movimento delle labbra e parlato (lip-sync errors); artefatti sonori nei cloni vocali

9.2.2 Difese Operative

- Cryptographic Provenance: Credenziali crittografiche negli asset aziendali ufficiali
- Multi-Channel Verification: Conferma di richieste sensibili tramite secondo canale pre-stabilito
- Real-time Audio Engine: Analisi spettrale della voce per rilevare cloni durante i meeting
- Challenging Attivo: Chiedere azioni imprevedibili durante interazioni live (girare la testa, coprire parte del volto)

9.3 Trasparenza Societaria – Sistema BORIS e UBO

Il Beneficial Ownership Register Interconnection System (BORIS) collega i registri nazionali centrali degli stati UE. L'interoperabilità è garantita dal Beneficial Ownership Data Standard (BODS). Dopo la sentenza CJEU del 2022, l'accesso è limitato alle autorità e ai soggetti con 'legittimo interesse' documentato.

- Soglia tradizionale per UBO: 25% (tendenza verso 10% in settori ad alto rischio o in presenza di PEP)
- La registrazione deve includere il controllo de facto: diritti di veto, patti parasociali, capacità di nominare gli amministratori

10. Conclusioni

10.1 Valore della OSINT Correttamente Applicata

La due diligence OSINT, quando condotta in conformità al GDPR, al Codice Privacy italiano e alle normative antiriciclaggio, rappresenta uno strumento strategico di riduzione del rischio.

Correttamente applicata:

- Identifica precocemente red flag (procedimenti, insolvenze, reputazione negativa), riducendo perdite economiche e reputazionali
- Integra compliance AML/KYC con intelligence preliminare, anticipando segnalazioni UIF
- Supporta governance 231/2001, fornendo intelligence proattiva ai CdA e Organismi di Vigilanza
- Offre difesa legale: una OSINT documentata e conforme è utilizzabile in contesti civili, amministrativi e investigazioni difensive penali

10.2 Raccomandazioni per Implementazione Responsabile

- PROTOCOLLARE: Adottare protocolli scritti di due diligence OSINT inclusi LIA, minimizzazione, tracciabilità
- FORMARE: Educare analisti su limiti legali, GDPR, tassonomia fonte lecita vs illecita, OPSEC
- DOCUMENTARE: Audit trail, LIA, policy, formazione, consent forms (ove applicabile)
- SUPERVISIONARE: Coinvolgere DPO in analisi complesse su dati sensibili
- CANCELLARE: Implementare processo data destruction, verificare esecuzione, certificazione
- AGGIORNARE: Monitorare evoluzione GDPR (AI Act, direttive UE), aggiornare protocolli

10.3 La Filosofia del 'Centauro' nel 2026

Le organizzazioni che prospereranno sono quelle capaci di bilanciare la velocità dell'automazione IA con il giudizio critico umano: l'IA gestisce il carico pesante (raccolta, sintesi, traduzione in tempo reale), mentre l'esperto umano fornisce l'ipotesi creativa e i parametri etici. In un mondo dove la realtà digitale è sempre più manipolabile, l'abilità di estrarre fatti verificabili da fonti aperte rimane l'unica vera difesa contro l'incertezza del mercato globale.

Appendice A – Tassonomia delle Tipologie di Due Diligence

A.1 Hard Due Diligence (Quantitativa)

- Financial DD: Bilanci storici e proiettati, flussi di cassa, qualità degli utili (QoE), debiti e passività nascoste, working capital
- Tax DD: Contenziosi tributari, imposte dirette e indirette, transfer pricing, tax ruling, perdite fiscali
- Legal DD: Contratti significativi, IP (brevetti, marchi, copyright), contenziosi, conformità normativa di settore, licenze
- Operational DD: Supply chain, asset tecnologici, processi produttivi, gestione qualità, dipendenza da risorse critiche
- IP DD: Validità e titolarità brevetti, marchi registrati, copyright, trade secrets, accordi di licenza

A.2 Soft Due Diligence (Qualitativa)

- Commercial DD: Posizionamento di mercato, quota mercato, customer base, barriere all'ingresso
- Strategic DD: Piano strategico, sinergie con l'acquirente, sostenibilità modello di business
- HR DD: Struttura organizzativa, contratti di lavoro, piani di incentivazione, dipendenti chiave, relazioni sindacali
- Environmental DD: Autorizzazioni ambientali, bonifiche, consumi energetici, certificazioni (ISO 14001, EMAS)
- ESG DD: Politiche ambientali, responsabilità sociale, governance aziendale, rating ESG
- Technical DD: Architettura IT, cybersecurity, asset tecnologici, roadmap tecnologica
- Reputational DD: Sentiment mediatico e social, crisi reputazionali passate, brand awareness, gestione reputazione online

A.3 Applicabilità OSINT alle Tipologie di Due Diligence

Tipologia DD	Contributo OSINT	Fonti Principali
Financial DD	Verifica rating, bilanci pubblici, procedure concorsuali	Cerved, Cribis, Registro Imprese, Gazzetta Ufficiale
Legal DD	Sentenze pubbliche, contenziosi, registri imprese	Giustizia.it, Portale Giustizia, Registro Imprese
Commercial DD	News, social listening, analisi settore	Google News, Social Media, Report di settore
HR DD	LinkedIn, recensioni, albi professionali	LinkedIn, Glassdoor, Ordini Professionali
ESG DD	Report sostenibilità, rating ESG, controversie	Siti aziendali, Database ESG, Stampa
Reputational DD	News, social media, forum, sentiment analysis	Google News, Social Media, Forum
Technical DD	Shodan, CVE database, analisi tecnica pubblica	Shodan, Censys, Database vulnerabilità

Appendice B – Framework Legitimate Interest Assessment (LIA)

B.1 I Tre Test della LIA (EDPB Guidelines 1/2024)

B.1.1 Purpose Test (Test dello Scopo)

- Identificare l'interesse legittimo specifico (non generico 'business improvement')
- L'interesse deve essere lecito, chiaramente definito, reale (non ipotetico)
- Documentare i beneficiari dell'interesse (organizzazione, terzi, società nel suo complesso)
- Domanda chiave: 'Perché vogliamo processare i dati? Cosa stiamo cercando di ottenere?'

B.1.2 Necessity Test (Test di Necessità)

- Verificare se il processing è effettivamente necessario per raggiungere l'interesse
- Verificare se esistono metodi meno invasivi per ottenere lo stesso risultato
- Verificare se il processing è proporzionato allo scopo
- Applicare il principio di data minimization

B.1.3 Balancing Test (Test di Bilanciamento)

- Natura dei dati: dati sensibili? dati di minori?
- Contesto del processing: relazione con l'interessato? aspettative ragionevoli?
- Impatto: danno potenziale, discriminazione, danno reputazionale?
- Salvaguardie: misure tecniche e organizzative implementate
- Opt-out: possibilità di opposizione da parte dell'interessato

B.2 Template LIA per OSINT Due Diligence

1. DESCRIZIONE PROCESSING

- Dati personali raccolti: [es. nome, cariche, precedenti giudiziari pubblici]
- Fonti: [es. Registro Imprese, giustizia.it, LinkedIn pubblico]
- Finalità: [es. valutazione rischio commerciale pre-contrattuale]

2. IDENTIFICAZIONE INTERESSE LEGITTIMO

- Interesse perseguito: [es. prevenzione frodi, compliance AML]
- Beneficiari: [es. azienda committente, partner commerciali]
- Conformità legale: [verifica conformità normativa applicabile]

3. ANALISI NECESSITÀ

- Il processing è necessario? [Sì/No]
- Alternative considerate: [es. verifica diretta presso enti]
- Perché alternative insufficienti? [es. tempistiche, costi, incompletezza]
- Minimizzazione: [solo dati strettamente necessari]

4. BALANCING TEST

- Natura dati: [dati pubblici professionali vs dati sensibili]
- Aspettative interessato: [persona pubblica vs privata]
- Impatto potenziale: [danno reputazionale? discriminazione?]
- Salvaguardie: [accesso limitato, crittografia AES-256, cancellazione 12 mesi]
- Opt-out: [possibile? come gestito?]

5. DECISIONE

- Legitimate interest applicabile? [Sì/No]
- Motivazione: [bilanciamento favorevole al titolare perché...]
- Data: [ante-processing – obbligatoria]
- Responsabile: [DPO/Responsabile Privacy/firma]

6. REVISIONE

- Prossima review: [data]
- Trigger per revisione anticipata: [cambio finalità, nuova normativa]

Riferimenti Bibliografici e Normativi

Normativa Primaria

- Regolamento (UE) 2016/679 (GDPR) – Regolamento Generale sulla Protezione dei Dati
- D.Lgs. 30 giugno 2003, n. 196 – Codice Privacy Italiano (coordinato con D.Lgs. 101/2018)
- D.Lgs. 8 giugno 2001, n. 231 – Responsabilità amministrativa delle società
- TULPS (R.D. 18 giugno 1931, n. 773) – Articoli 17, 134, 140
- D.M. 269/2010 – Regolamento agenzie investigative
- L. 20 maggio 1970, n. 300 – Statuto dei Lavoratori, Articoli 4 e 8
- Codice Penale Italiano – Art. 594 (Diffamazione), Art. 615-ter (Accesso abusivo), Art. 616 (Violazione privacy)

Linee Guida e Provvedimenti

- EDPB Guidelines 1/2024 – Legitimate Interest Assessment
- EDPB/EDPS Joint Opinion 2/2026 – Digital Omnibus Regulation
- Garante Privacy Italiano – Provvedimento n. 107 del 24 febbraio 2026 (Doc-Web 10224096) – Caso Amazon
- ICO UK – Legitimate Interests Guidance

Fonti Online e Database

- Ministero della Giustizia – Pubblicazione sentenze: <https://www.giustizia.it/>
- Corte Suprema di Cassazione – Banca dati giuridica: <https://www.cortedicassazione.it/>
- ANAC – Agenzia Nazionale Anticorruzione: <https://www.anticorruzione.it/>
- UIF – Unità Informazione Finanziaria: <https://uif.bancaditalia.it/>
- EUIPO – Database Marchi UE: <https://euipo.europa.eu/>
- UIBM – Ufficio Italiano Brevetti: <https://uibm.mise.gov.it/>
- EDGAR (SEC) – Database società quotate USA: <https://www.sec.gov/edgar>
- OpenCorporates – Database societario globale: <https://opencorporates.com/>
- OpenOwnership – Registro titolari effettivi: <https://www.openownership.org/>

Fonti e Rapporti Tecnici

- Fivecast – OSINT Predictions for 2026: <https://www.fivecast.com/blog/osint-predictions-for-2026/>
- Blackdot Solutions – OSINT in 2026: Key Trends: <https://blackdotsolutions.com/blog/osint-in-2026>
- Osavul – Open Source Investigations Guide 2026: <https://www.osavul.cloud/blog/open-source-investigations-guide>
- Cyble – Deepfake-as-a-Service Exploded in 2025: <https://cyble.com/knowledge-hub/deepfake-as-a-service-exploded-in-2025/>
- UncovAI – Deepfake Detection & Prevention Guide 2026: <https://uncovai.com/deepfake-detection-prevention-guide-2026/>
- Forbes – The Year Authenticity Breaks: Deepfakes, AI and the Battle for Trust in 2026: <https://www.forbes.com/councils/forbesbusinesscouncil/2025/12/30/>
- coredo.eu – UBO registries in 2026: <https://coredo.eu/ubo-registries-in-2026-how-banks-verify-transparency-in-offshore-jurisdictions/>
- Moody's – Verifying Beneficial Owners in the EU: <https://www.moody's.com/web/en/us/kyc/resources/insights/verifying-beneficial-owners-in-the-eu-a-multisource-path.html>
- JDSupra – FinCEN Simplifies CDD Requirements: <https://www.jdsupra.com/legalnews/fincen-simplifies-cdd-requirements-for-2792162/>

- MDPI – LLMs for Social Network Analysis: <https://www.mdpi.com/2076-3417/16/1/163>
- Splunk – 2026 Predictions: The Future of Investigation: https://www.splunk.com/en_us/blog/ciso-circle/ai-generative-ui-security-analyst-investigations.html
- Social Links – Top 10 OSINT Tools for 2026: <https://blog.sociallinks.io/top-10-osint-tools-products-solutions-and-software-for-2026/>
- TrasportoEuropa – Garante Privacy blocca Amazon: <https://www.trasportoeuropa.it/notizie/logistica/garante-privacy-blocca-amazon-su-alcuni-dati-sui-lavoratori/>
- knightsbridge.ae – EU beneficial ownership registers 2026: <https://knightsbridge.ae/eu-beneficial-ownership-registers-what-uae-structures-must-disclose-in-2026/>

– *Fine del Documento* –

DUE DILIGENCE OSINT | White Paper Tecnico-Operativo | Versione 1.0 | Marzo 2026